

System Specific Policy for Passwords

Semir Hot, Harrison Maksimik

March 10, 2024

Contents

1	Statement of Policy	1
1.1	Purpose	1
1.2	Scope	1
1.3	Responsibilities	1
1.4	Definitions	2
1.5	Background	2
2	Security Concerns	2
2.1	Hashing Algorithms	2
2.2	Password Complexity	3
3	Security Controls	3
3.1	Password Length	3
3.2	Password Composition	3
3.3	Password Storage	3
3.4	Password Lifetime and Reuse	4
3.5	Authentication System	4
3.6	Administrator Accounts	4
4	Scheduled Reviews	5
5	References	5

1 Statement of Policy

1.1 Purpose

The purpose of this policy is to provide a set of procedures that should be implemented in our organization’s infrastructure which enforce the use of

secure, complicated passwords. In particular, this infrastructure should be provided by the Modisoft platform, which will then share user authentication with other systems in our organization which require logins.

1.2 Scope

The scope of this system-specific policy extends only to the organization's authentication platform Modisoft, all user data managed by Modisoft, other systems which require authentication, passwords, and any employee, contractor, or third party worker who works on or uses any system which requires authentication.

1.3 Responsibilities

It should be the responsibility of the CISO to respond to new business needs not considered in this document, and to keep this document up-to-date. System administrators, contractors and other qualified personnel, along with third-party workers, should be responsible for the implementation of the listed security measures. All other employees and workers should be responsible for following the spirit of this document; it should not be acceptable to circumvent the security controls implemented as described in this document. All personnel are required to read, understand and follow the guidelines listed in this document. Should new business needs conflict with these controls, a notice containing relevant details should be sent as soon as possible to the employee's line manager, other information security personnel, or the CISO via email.

1.4 Definitions

- Hash: A one-way cryptographic function which converts plaintext into undecipherable text.
- Salt: Each password should receive a randomly generated string which is attached to the password before hashing. This prevents rainbow table attacks.
- Pepper: After hashing each password, an additional HMAC hash should be applied to the hashed password using a key shared between all passwords in the organization.

1.5 Background

Modisoft is our organization's bespoke management software written by a third-party contractor. This platform provides controls for the management of our business based on an access control model, meaning users are required to authenticate with the Modisoft system in order to access the specific controls they are privileged to. In order to keep authentication consistent across all network-attached information systems, Modisoft's authentication system should act as a broker for all other logins within the network. This also eases the burden of the creation of access control systems throughout the network, as Modisoft has some built-in access control capabilities. Because Modisoft is completely controlled by our organization, all necessary changes to Modisoft to support this security policy can be made with the help of our contractor.

2 Security Concerns

2.1 Hashing Algorithms

Certain hashing algorithms have been made obsolete with the advancements in computational power. Algorithms like MD5 are no longer suitable for cryptographic purposes, and thus, should not be used for the storage of passwords in our organization. It is also necessary that all password hashes are salted in order to prevent rainbow table attacks.

2.2 Password Complexity

Passwords for each user should meet certain complexity guidelines to prevent brute force attacks. These requirements must be updated frequently as general computing power increases. Older wisdom for password security was to generate passwords which were at least 8 characters long, and contained upper and lower case letters, numbers, and symbols. However, it is now possible to crack such an 8 character password using brute force methods in approximately 5 minutes on modern hardware¹. As computers become more powerful, it may be required that our organization consider other methods of authenticating users in the future as required password complexity increases.

3 Security Controls

3.1 Password Length

According to the tech.co website¹, an 8 character length password is no longer tenable. Additionally, while an 11 character length password *can* currently offer strong security, our organization must consider the password lifetime policy and plan for long-term security over an entire password lifetime period. Therefor, our organization should mandate that new passwords be made with a minimum of 12 characters. This requirement is subject to change annually.

3.2 Password Composition

Our organization should ensure that new passwords are composed of at least one number character, at least one uppercase character, at least one lowercase character, and at least one special symbol character.

3.3 Password Storage

Passwords should be stored only in a hashed format. In particular, the PBKDF2-SHA256 algorithm should be used for initial password hashing. This algorithm provides automatic salting, so our organization should not be required to explicitly implement this feature. Additionally, our organization should further protect our passwords using peppering from the PBKDF2-HMAC-SHA256 algorithm. In order to implement this feature, a secrets vault should be created in our organization to contain the password pepper. This pepper should be rotated annually alongside the password rotation.

3.4 Password Lifetime and Reuse

Passwords should be rotated annually. This should be a simultaneous rotation of *all* organization passwords, no matter the password's age. This process should be immediately activated following the annual review of this policy, implementing any new security controls made during this review and update process. Following this rotation, other components of this policy should be activated, such as the creation of a new pepper key. Passwords should not be permitted to be reused, even if they remain within the specifications of this policy, in the next password cycle.

3.5 Authentication System

Modisoft will be used as the central authentication system for our organization. Each network-attached service should accept authentication of general users (not system administrators) only from the Modisoft system. It should be the duty of the Modisoft service to implement the restrictions on password creation listed in this policy. These controls should be implemented by Modisoft in a data-based format such that system administrators can easily make changes to the system's password requirements as this policy is updated.

3.6 Administrator Accounts

Some devices in our organization's network may not be practically or safely linked to the Modisoft authentication system, such as the authentication for the network router control panel. In such cases, the network administrator(s) responsible for these devices should create a unique set of credentials specific to each of these devices, which still follows all security controls listed in this document aside from the controls listed in the Authentication System subsection. If peppering functionality is not offered by the system, this component of the security policy can also be disregarded. If the hashing algorithm listed in the Password Storage subsection is not available for a specific system, a system-specific policy for that asset should mandate the use of an alternative algorithm.

4 Scheduled Reviews

This policy should be reviewed by the CISO and other parties of interest on an annual basis before each new password lifetime cycle. New technologies may make the current security controls obsolete in the future; each of the provided guidelines under the *Security Controls* section should be carefully reviewed during this time.

5 References

1. <https://tech.co/password-managers/how-long-hacker-crack-password>
2. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html